

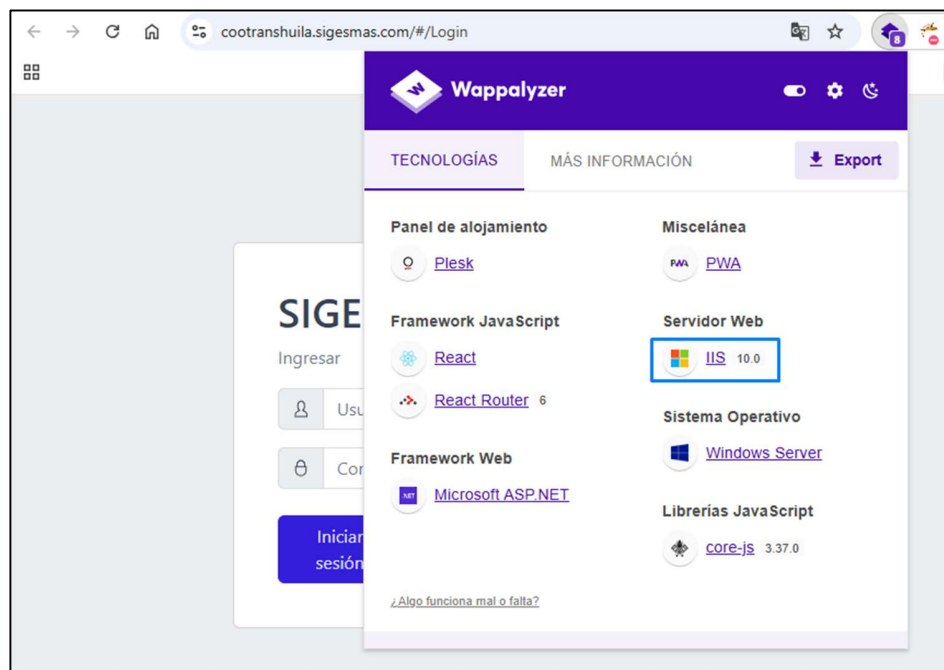


Ilustración 2. Exposición de versiones tecnológicas, en el sitio <https://www.cootranshuila.com> - <https://cootranshuila.sigesmas.com/#/Login> - <https://erpcootranshuila2024.sitransas.com.co/inicio>

5.2.2. A02-Ausencia de cabeceras de seguridad HTTP

Descripción general.

Durante el análisis de seguridad, se identificó la ausencia de varias cabeceras HTTP de seguridad importantes. Estas cabeceras permiten establecer políticas de protección del lado del cliente, reforzando la seguridad frente a ataques comunes del navegador y mejorando la integridad, confidencialidad y disponibilidad de la aplicación web.

Detalles del hallazgo.

El análisis de las respuestas HTTP en las aplicaciones reveló que no se encuentran configuradas algunas de las siguientes cabeceras de seguridad:

Cabecera	Estado	Función
Content-Security-Policy (CSP)	No configurado	Previene la ejecución de scripts no autorizados (mitiga XSS).
X-Frame-Options	No configurado	Previene ataques de clickjacking evitando que el sitio sea cargado en iframes.
X-Content-Type-Options	No configurado	Previene el MIME-sniffing para evitar ejecución de contenido malicioso.
Strict-Transport-Security (HSTS)	No configurado	Obliga al navegador a usar HTTPS en futuras solicitudes.

Impacto potencial.

La falta de estas cabeceras deja a la aplicación expuesta a múltiples vectores de ataque, entre ellos:

- Cross-Site Scripting (XSS): Sin CSP, scripts inyectados por atacantes pueden ejecutarse libremente.
- Clickjacking: Un atacante podría embeber el sitio en un iframe malicioso para capturar interacciones del usuario.
- MIME Sniffing: El navegador podría interpretar archivos como ejecutables, aunque no lo sean.
- Ataques Man-in-the-Middle (MiTM): La ausencia de HSTS permite redirecciones a HTTP inseguro y ataques de downgrade.

Técnica utilizada.

Metodología:

- Inspección manual de cabeceras HTTP mediante herramientas como curl.
 - `curl -I https://cootranshuila.sigemas.com/#/Login`
- Escaneo automatizado utilizando **SecurityHeaders.com** y **OWASP ZAP**, confirmando la ausencia de las cabeceras mencionadas.

Recomendaciones de mitigación.

Se recomienda configurar adecuadamente las siguientes cabeceras de seguridad en la respuesta HTTP del servidor:

- **Content-Security-Policy (CSP).**
 - Content-Security-Policy: default-src 'self';
 - Permite definir orígenes válidos para scripts, estilos, imágenes, etc.
 - Personalizar según necesidades específicas de la aplicación.